WEEKLY PROGRESS REPORT -09

SSLCOMMERZ SANDBOX PAYMENT & SIMULATED INTERNAL ESCROW INTEGRATION

MuktoKormo • Sprint 09

PROJECT MuktoKormo (Freelance Marketplace)	**SPRINT SCOPE** Payment Gateway & Escrow Flow	**REPORT DATE** November 11, 2026
APPLICATION STACK Next.js 16 • React 19 • Tailwind v4	**DATABASE & AUTH** Supabase PostgreSQL, RLS & RPCs	**GATEWAY MODE** SSLCOMMERZ Sandbox (isLive=false)
TEAM MEMBER 01 Abdul Ahad Akid (2207018)	**TEAM MEMBER 02** Ashraful Hosen (2207042)	**BUILD STATUS** Sandbox & Integration Verified

1. Executive Summary & Week 9 Objectives

CORE DELIVERABLE

In earlier sprints, MuktoKormo established live Supabase authentication, job posting, bidding, role-aware dashboards, TalkJS messaging, and contract workspace routing, while checkout and wallet settlement remained simulated client-side placeholders. **Week 9** delivers an end-to-end **SSLCOMMERZ Sandbox payment integration** paired with a fail-closed, ACID-backed **Simulated Internal Escrow Ledger** in PostgreSQL. Clients can fund active BDT contracts through the hosted SSLCOMMERZ Sandbox EasyCheckOut gateway, freelancers progress deliverables through structured review stages, clients release milestone settlements with a server-enforced 10% platform commission split, and administrators audit transactions and moderate refund requests.

01 **Initiate Checkout**
Server computes 10%/90% BDT split & calls v4 API.

02 **Sandbox Redirect**
User completes Card/bKash/Nagad on EasyCheckOut.

03 **Fail-Closed Verify**
Success & IPN cross-check validatorserverAPI.php.

04 **Escrow FUND Entry**
PostgreSQL RPC atomically marks FUNDED ledger row.

05 **Release / Refund**
Client work approval credits 90% net or Admin refunds.

2. Database Schema Extensions, Guards & Atomic RPCs

2 MIGRATIONS

Two SQL migrations (`20261111000000_payments_escrow_system.sql` and `20261111010000_harden_contracts_trigger_context.sql`) extend the live schema with strict financial immutability checks and Row Level Security:

TABLE / OBJECT	KEY PURPOSE & COLUMNS ADDED	SECURITY & INTEGRITY ENFORCEMENT
`public.contracts`	Extended with `payment_status` , `work_status` , `platform_fee_pct` (10%), fee/payable amounts, submission deliverables, and timestamps.	Trigger `contracts_before_write_guard_trg` blocks client modification of financial columns; checks JWT claim role inside helper.
`public.payments`	Tracks one authoritative BDT checkout record per contract session (unique `MKP-*` `transaction_id` , `validation_id` , gateway method).	Party-scoped & Admin SELECT only; client direct writes rejected by RLS; updated solely via server RPCs.
`public.payment_transactions`	Sanitized append-only audit telemetry of gateway events (`INITIATE` , `SUCCESS_CALLBACK` , `IPN_CALLBACK` , `VALIDATION_CHECK`).	`sanitizeGatewayPayload()` recursively strips `store_id` , `store_passwd` & `verify_sign` prior to persistence.
`public.escrow_ledger`	Immutable accounting trail recording `FUND` , `RELEASE` , and `REFUND` rows (explicitly marked `is_simulated = TRUE`).	Append-only via `SECURITY DEFINER` RPCs (`EXECUTE` revoked from `anon` / `authenticated`).
`public.refund_requests` & `notifications`	Tracks client refund requests & Admin approvals (`SIMULATED_INTERNAL` or Sandbox API), plus deduplicated alerts keyed by `event_key` .	Open refund state blocks premature start/submit/release APIs (`409 REFUND_IN_PROGRESS`).

3. Server API Endpoints & Key Week 9 Fixes

17 ROUTES + FIXES

Implemented Backend Route Groups

- **Gateway & Callbacks (`/api/payments/*`):** `initiate` , `validate` , `success` , `fail` , `cancel` , `ipn` , `dashboard` , `ledger` , and `refunds` with strict BDT/amount verification and duplicate-IPN idempotency.
- **Contract Lifecycle (`/api/contracts/[id]/*`):** `GET` workspace payload plus `start-work` , `submit-work` , `request-revision` , and `approve-release` enforcing role checks.
- **Admin & Alerts (`/api/admin/*`):** `/api/admin/payments` , `/api/admin/refunds/[id]` , and `/api/notifications` .

Notable Week 9 Stability & Integration Fixes

- **Live Contract Alias Resolution:** Updated `/api/contracts/[id]` and workspace loader to resolve synthetic `ctr-<proposalUuid>` routes directly to live database contracts instead of falling back to static `MK-CTR-8842` preview data.
- **Ngrok Tunnel Compatibility:** Added wildcard `*.ngrok-free.dev` / `APP_URL` origins to `next.config.ts` (`allowedDevOrigins`) and fixed cookie/redirect host resolution for external webhook delivery.
- **Sandbox Environment Guard:** Blocks live credentials or placeholders when `SSLCOMMERZ_IS_LIVE !== "false"` .

4. End-to-End Contract Funding, Gateway Redirect & Ledger Settlement

LIVE UI CAPTURES

Figures 1–3 below capture the live execution path running on MuktoKormo (connected to Supabase PostgreSQL and the live SSLCOMMERZ Sandbox gateway). Financial values are never accepted from browser payloads: checkout amounts and commission splits are computed authoritatively on the Next.js server before requesting a Sandbox session key and validated post-callback before inserting `FUND` or `RELEASE` ledger records.

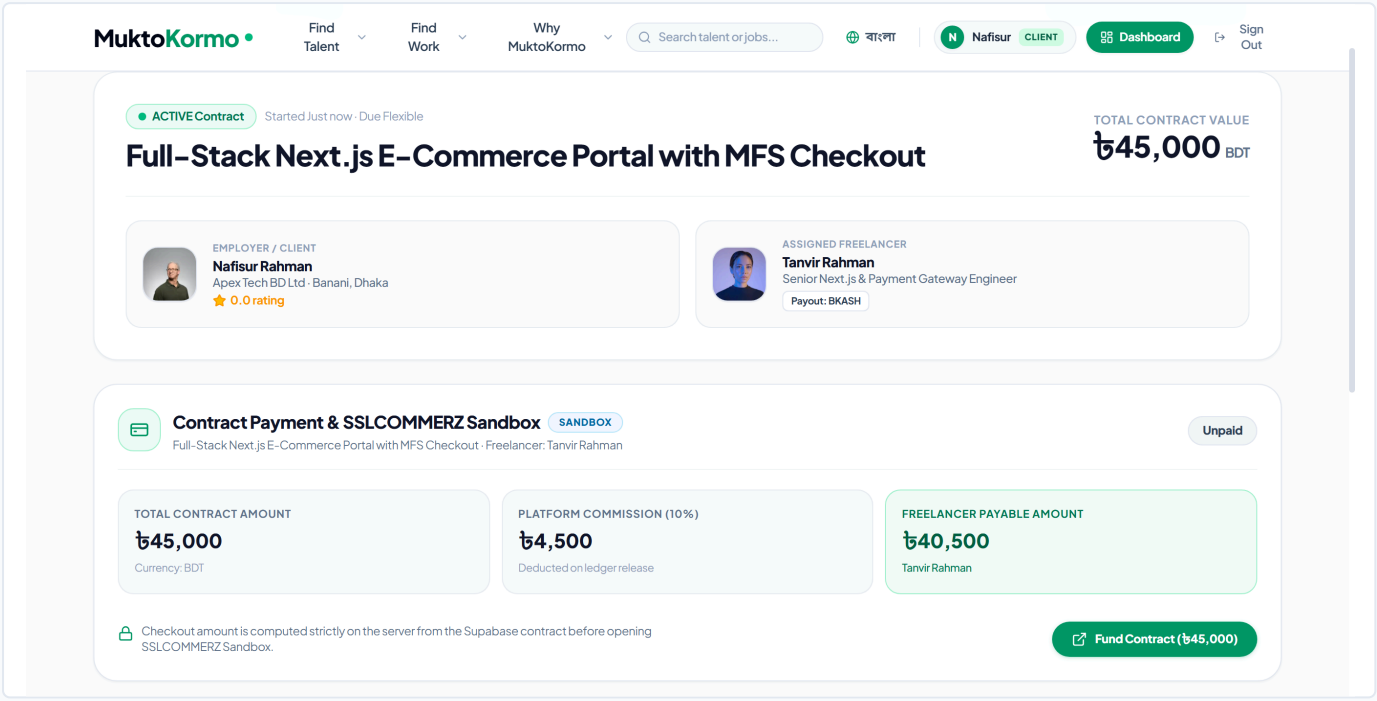


Figure 1 — Contract Workspace Payment Card (`/contracts/[id]`): Displays live contract metadata, server-derived fee split (**10% platform commission: ৳4,500**, **90% freelancer payout: ৳40,500**), and the client funding trigger invoking `POST /api/payments/initiate`.

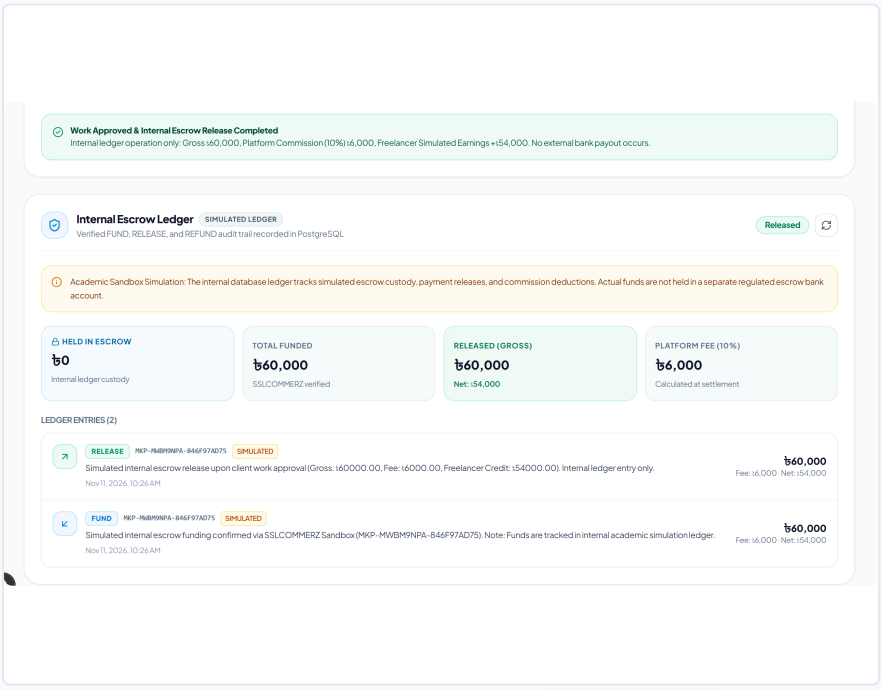


Figure 2 — Work Approval & Immutable Escrow Ledger (`/contracts/[id]`): Shows the completed delivery release banner, explicit academic simulation disclosure, zero remaining custody balance, and sequential `FUND` → `RELEASE` audit entries recorded in `public.escrow_ledger` for ৳60,000 gross (৳54,000 net).

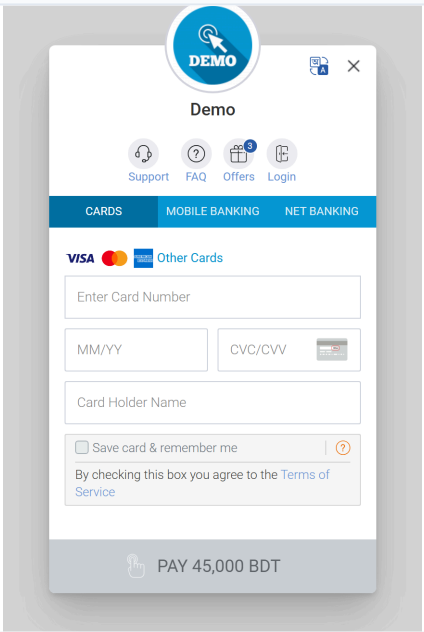


Figure 3 — SSLCOMMERZ Sandbox Gateway: Live session redirect onto `sandbox.sslcommerz.com` EasyCheckOut verifying server-enforced **45,000 BDT** across Cards, Mobile Banking (bKash/Nagad), and Net Banking.

Architectural Safeguard Highlight: Success redirects (`POST /api/payments/success`) never mark a payment as funded on query parameters alone. Every callback independently calls `validationserverAPI.php` , asserts exact BDT amount & currency equality, and settles idempotently inside PostgreSQL so duplicate callbacks or IPNs cannot double-credit the ledger.

5. Role-Aware Payment & Commission Consoles

CLIENT & ADMIN SURFACES

Both Client (`/dashboard/client?tab=payments`) and Admin (`/dashboard/admin?tab=payments`) consoles aggregate live totals directly from PostgreSQL—tracking held sandbox escrow, total released spending, platform commission, and open refund queues while preserving tenant isolation via Supabase RLS.

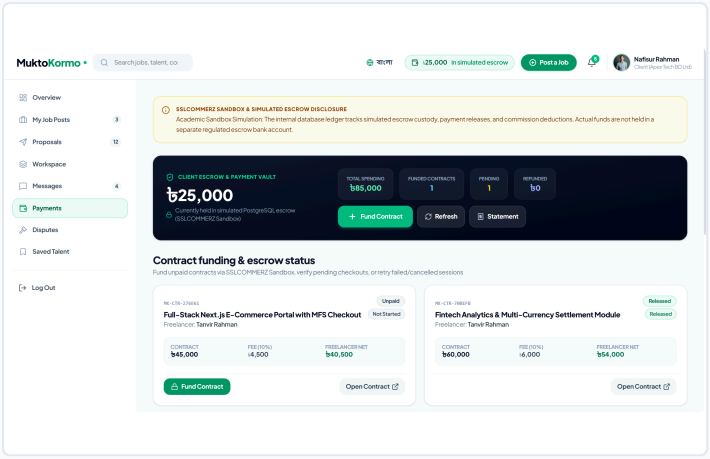


Figure 4 — Client Payments & Escrow Vault (`/dashboard/client?tab=payments`): Live client summary showing ৳25,000 held in simulated escrow, ৳85,000 total volume, and contract funding controls.

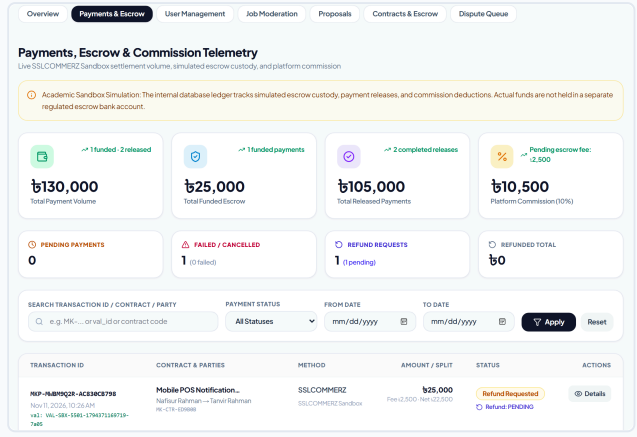


Figure 5 — Admin Escrow & Refund Console (`/dashboard/admin?tab=payments`): Platform telemetry (৳130,000 volume, ৳10,500 commission), filters, and pending refund moderation row.

6. Quality Assurance & Automated Test Results

OBSERVED RUNS

VERIFICATION CHECK	RESULT	COVERAGE & KEY EVIDENCE
TypeScript (`npx tsc --noEmit`)	**PASS (0 errs)**	Verified cleanly across all App Router API routes, server libraries, types, and UI components.
ESLint (`npm run lint`)	**PASS (0 errs)**	Exit code 0 across codebase; 62 pre-existing warnings only (legacy `<img>` & modal unused vars).
Unit Tests (`payment-system.test.ts`)	**9 / 9 PASS**	Verified 10%/90% BDT rounding, UUID & `ctr-` parser, sandbox guard, 30-char `tran_id` limit, credential scrubbing, and callback parsing.
Live Integration (`verify-15-scenarios.mjs`)	**15 / 15 PASS**	Executed end-to-end against Next.js APIs, live SSLCOMMERZ Sandbox APIs, and Supabase RLS/RPCs (forged `val_id` block, duplicate IPN, work/release/refund flows, tamper guards).
RLS & Tamper Audit	**VERIFIED**	Blocked direct client updates on `payments` , `contracts` financial columns, and `freelancers.earned_bdt` ; verified clean DB restore after runs.

7. Next Sprint Plan & Sandbox Simulation Scope

ROADMAP

Next Week Objectives (Week 10)

- Add Supabase Storage bucket upload hooks for work deliverables alongside repository/demo links.
- Polish Freelancer Earnings & Payout Method analytics (`/dashboard/freelancer?tab=wallet`) and run full responsive mobile UAT.
- Complete pre-production merchant onboarding checklist for future SSLCOMMERZ live key promotion.

Academic Sandbox Boundary Notice

This integration targets **SSLCOMMERZ Sandbox** exclusively (`SSLCOMMERZ_IS_LIVE=false`). All escrow custody balances, `RELEASE` credits, and `SIMULATED_INTERNAL` refunds operate on an academic PostgreSQL accounting ledger; no live commercial funds, regulated bank escrow holds, or external MFS payouts occur in this environment.